CST8919 DevOps Security

Complete study notes | Modules 1–6

A reorganized, compact reference drawn from the 29 supplied lesson PDFs. It retains the instructional explanations and examples while leaving out self-check activities, quizzes, assignments, and exam work.

Contents

Module 1. Foundations and domains of security

Information technology security • Domains of security

Module 2. Cloud security and shared responsibility

Security • Security requirements • Myths about cloud security

Module 3. Privacy and confidentiality

Privacy and confidentiality • Is cloud bad for privacy? • Threats to confidentiality • Commonly exploited vulnerabilities • Protecting confidentiality

Module 4. Integrity and authenticity

Integrity and authenticity • Breaches to integrity • Security controls for integrity and authenticity • Analysis • Case study

Module 5. Availability and resilience

Availability requirements • Threats to availability • Attacks against availability • Security controls for availability • Content delivery network (CDN)

Module 6. Repudiation and nonrepudiation

Repudiation and nonrepudiation • Implementation of nonrepudiation • Limitations of nonrepudiation mechanisms

How to use this guide: start with each module overview and key terms, then read the lessons in order. The source material is reflowed to reduce the large empty areas in the original printouts. External articles and videos mentioned by the course are not reproduced here.

Module 1 | Foundations and domains of security

Information security begins with authorized use: a person or process should read, create, change, or delete data only within its permissions. Security is therefore a risk management problem. Identify possible harm, estimate its likelihood and impact, then select controls that reduce the risk to an acceptable level.

The course traces security from physical protection of early computers to personnel, operations, network, communications, cyber, and cloud security. These domains overlap. A secure application still depends on trustworthy people, facilities, devices, networks, and processes.

Bollard: A sturdy short post used, for example, to stop vehicles from reaching a protected building.

Information technology security

Before we start, read this article:

7 Most Infamous Cloud Security Breaches Arcserve

The notion of information security can be resumed to a simple premise: that the information is only used in an authorized way. This means that anybody who consults, uses, creates, modifies, or deletes data only does so under authorization, and never beyond that authorization.

Beyond that simple proposition exist several concerns. When talking about information security, we must consider the notion of risk. Risk and security are two facets of the same coin. However, risk lends itself to assessment and evaluation more naturally. We can list types of injuries that can be suffered, and determine the risk that it could happen, and which countermeasures would adequately protect us. Increasing security, in other words, becomes a question of lowering the risk.

In this module, we will observe the evolution of risk management for information systems and assess the role that cloud service providers play for information security.

Securing the infrastructure

First, information is dependent on the technology that we use to manipulate it, and therefore the technology must be protected at the same level as the information for the security measures to be adequate. That technology will include devices, networks, firmware and software, protocols, operating systems, and applications. Every aspect of the infrastructure must provide the assurance that it can protect the security of the information. The level of security for the information will never exceed the level of security of the infrastructure used to process, store, and transmit that information. Securing the infrastructure is a very complex and multifaceted problem, for which there is no perfect solution.

Granting authorizations

Second, it needs to be determined how authorization will be provided? Who can have access to the information? There are generally three components required for an access to be considered “authorized”. One component is an account that has been granted the privileges and permissions to perform the action in question. Without access to such an account, the manipulation cannot happen. Another component is the security clearance required for access. In many settings, this is either ignored or implicit, however several organizations implement a classification system where information is “labelled” based on its sensitivity. The label provides a quick indication that might restrict the people who can access it. For example, if a folder is left on a table in a boardroom and the label on it says, “TOP SECRET”, someone finding that document that does not have that clearance should not open the folder to consult the documents inside. Having the proper clearance, regardless of accounts and permissions, is a requirement to view information. Of course, accounts and permissions should be provided in accordance with security clearance status. The third component is often referred to as the “need-to-know”. Basically, even if account permissions and security clearance are at the appropriate levels, information should not be accessed unless there is a legitimate business to do so. That means that the person finding the “TOP SECRET” folder should not open it if it that person has a TOP SECRET clearance if there is no legitimate business use. Curiosity does not count.

As you can see, determining who should or should not have access to information can be rather complex. Managing accounts, granting permissions, and revoking privileges are an important part of information security.

Trust but verify

Organizations must keep tabs on the individuals accessing their systems and their information. These individuals can be customers, partners, auditors, third-parties, employees, and administrators. There is a bit of a conundrum with the security protocols. They mostly come down to trust: in the software, in the protocols, in the devices, but also in the individuals that make all the business operations happen. A common saying in the security world is “trust but verify”. This means that we can trust individuals, and such a thing is rather unavoidable, but we should also keep track of the actions that users will perform and ensure that it is in keeping with how they should behave. This surveillance is typically enabled through logging, monitoring, and auditing of user activity.

Domains of security

In this section, we will look at some of the subdomains of security that come together to create a fully featured security posture to protect the information and infrastructure.

Early days of information security

Computers have not been around for that long. The earlier computers were huge, requiring a lot of power, a lot of space, and a lot of expertise to be able to use them. And, they were only capable of very basic computations.

The U.S. Army was at the origin of many initiatives regarding the development of computing devices. A lot of the incentive came from the desire to decrypt enemy communications by using superior technology. The Turing Bombe, the device that was

instrumental in cracking German communications encrypted with the Enigma device, is often considered as a precursor to the computer.

Those early computers allowed long and painstaking process to be executed by an automated device instead of relying on slow and error-prone hand calculations. They were costly and intricate devices. The military secured the devices the same way that they secured everything else: through a physical perimeter and operational security. After all, the computers were within secure military

buildings and outposts, and they did not connect to other remote devices. The military would recruit talent from universities and the private sector to help with the development and use of the computer. Military security protocols were put in place, meaning that authorized personnel would have to first undergo a background security check, obtain security clearance, and be granted permission to work on the computer. The process included mandatory training and awareness about what the knowledge they would be entrusted with. When working on projects, they had to go physically to the location of the computer, pass through one or more security gates, and then enter the restricted area.

Physical security

This process highlights many of the security protocols still in use today. The first one we are looking at is physical security: the protection from risks coming from the physical environment. Physical security leverages physical barriers such as moats, gates, bollards, locked doors, and strong walls and ceilings to protect against unauthorized physical access. It aims to negate the risks from eavesdropping, intrusion, and physical destruction. It uses detection tools such as motion sensors, cameras, and security lighting. It also uses suppressants, such as water sprinklers, and chemical extinguishers. It deploys protection against accidental threats, such as power surges, floods, fires, and earthquakes. Many organizations use guards to monitor the physical environment and detect unwanted activity.

Personnel security

Along with physical security, personnel security has always been a major component of information security. After all, physical security will protect the physical environment from unauthorized access but will not be useful against authorized users that may seek to maliciously hurt the organization to serve their own interest. Those people are known as “insider threats” and are one of the biggest challenges when it comes to securing any system.

Personnel security is mostly preventative because it takes place before access is granted. Organizations will want to investigate individuals that are to receive access and privileges to make sure that they do not pose a threat. Depending on the sensitivity of the information, this background check can take many forms. Many organizations will do an online investigation and

talk to previous employers to get a sense of the individual. Other organizations hire experts to perform this investigation to uncover events of interest: criminal charges, association to known criminals, association to activist causes that could be of concern, gambling debts, addiction, money issues, etc. Anything that could reasonably be seen as a reason for the individual to exploit the organization must be discovered and analyzed. Beyond this, some organizations dealing with highly sensitive information such as national security programs will go as far as submitting candidates to a polygraph examination and/or a psychiatric evaluation to determine their fitness for employment. This security clearance process must be repeated regularly, every 10 years, or every 5 years, sometimes even more frequently.

Sharing resources on a computer

With computers becoming more powerful, and even more expensive, organizations that owned them were faced with an interesting question: how to maximize the use of the computer by letting more than one person use it at a time? With several different people using the same computer, the files needed to be protected from unwanted access and modification, the processes needed to run with some isolation so that they would not interfere with each other, and users needed to identify to the computer so that no one would “borrow” their allocated time on the scarce device. This problem saw the emergence of user accounts on computers, protected by weak passwords. The passwords did not need to be robust because it was to protect against abuse from pranky coworkers: other individuals that were security-cleared, trustworthy, and did not want to be kicked out of the organization.

This type of security is “information technology security”. It has to do with user accounts, permissions, privileges, and protecting the internal infrastructure from unauthorized access and modifications by other users of the system. IT security can be tricky, but modern operating systems have become very efficient at solving this type of problem. Security measures can be applied to restrict the behaviour and limit the risk from improper use of computers. Nevertheless, IT security requires constant vigilance

and operational diligence to avoid costly mistakes.

Network security

With the use of computers becoming more and more popular in organizations of all kinds, information technology was now routinely used to create and process documents. This allowed tasks to be performed faster and more efficiently, at lower error rates.

One of those mundane tasks that companies wanted desperately to improve was the transmission of documents from one location to another. The best that companies could achieve at that point was to use a messenger to walk over to someone else's desk and deliver the documents. Some organizations used a complex system of pneumatic tubes to transport the information quickly.

It seems like science-fiction, but it was not that long ago that this was a common internal communication system. (https://en.wikipedia.org/wiki/Pneumatic_tube)

Pneumatic tube

We take for granted the simplicity of sending instantaneous messages to transport any type of information that we want, but there was a time not long ago where this was a technological feat that organizations were very eager to inject into their day-to-day operations.

By connecting computers together to communicate with one another, workers were able to share resources and information quicker and better than ever before. Several different protocols were used to connect the computers together, and different protocols provided different advantages over others. Unfortunately, it also caused many compatibility issues in the early days of network communications.

With the implementation of networking tools in organizations, network security became a necessity and has been ever since. Network security manages restrictions on what can be sent over the network, limiting the possible sources and destinations of messages, and sometimes even their content. Network security operates at the layer that links computers together.

Communications security

Pretty soon, one of the main features of computers became their ability to communicate with one another remotely. By connecting private networks together, a global interconnected network of networks came about: the Internet. This worldwide communication platform allows unparalleled connectivity, and users can interact with distant systems quickly and efficiently. The Internet has profoundly changed our way of life. In its early days, the Internet was slow, clunky, unreliable, and very insecure. There soon came the need for a new branch of security: communications security.

To be fair, communications security was not exactly new, but applying it to communications outside of a military setting was definitely not typical. Because communications were transmitted outside of the protected physical perimeter, and potentially intercepted by hostile individuals, specific security measures needed to be applied.

Communications security employs a number of controls to verify the authenticity and integrity of communications, and protects the confidentiality of the data being exchanged through of use of cryptographic algorithms.

Cyber security

The emergence of the Internet brought forth a new type of threat: the online hacker. Individuals that use their intellect and knowledge to attack online systems, defeat security mechanisms, and compromise the confidentiality and integrity of information. With few people online using a slow

and clunky Internet, this problem was manageable. But, with the dramatic increase in the number of internet citizens, or "netizens", now reaching over half the global population, and the proliferation of computers and fast Internet connections, the rise of the criminal hacker has become a global and pressing concern.

This type of threat is difficult to deal with by usual means. The online hacker cannot be defeated through physical security since access is done from network communications. It is not an internal user, so personnel security does not apply either. Dealing with hackers requires resources in another type of security: cyber security.

Cyber security is the protection from threats coming in "from the wires". It requires experts that know how hackers proceed to defeat security and compromise systems so that they can efficiently counteract the procedures. The commercialization of

hacking has created a black market of cyber weaponry, exploits, and vulnerability research, where everything is bought and sold using untraceable communication protocols and cryptocurrency. Cyber security has become one of the main issues for industrialized countries, with alarming statistics concerning the rate and impact of cyber attacks still on the rise.

This article offers many interesting statistics about cybercrime data from a worldwide perspective.

300+ Terrifying Cybercrime and Cybersecurity Statistics

The threat coming from interconnected systems has superseded other types of threats, making cyber security the main security concern for most organizations. It has placed a lot of pressure on organizations to either increase their cyber security resilience or suffer devastating attacks at the hands of hackers.

Security for cloud computing technology

With our tour of security domains completed, we now have a better idea of what is required from an organization that aims to deliver services over the internet. Cloud service providers are an attractive target and must provide high levels of security to their customers and partners. During this course, we will observe how cloud providers manage physical, personnel, information, communications, and cyber security requirements in an extremely hostile environment.

Module 2 | Cloud security and shared responsibility

Cloud computing divides control of an IT system between the customer and a provider. A provider secures its facilities and underlying services, while the customer still has duties for identities, configuration, applications, and data. The exact boundary changes across infrastructure, platform, and software services.

Security requirements must be tailored to the organization and its risks. Purchasing more tools or relying on the provider alone does not replace a coherent security design, clear ownership, monitoring, and staff participation.

Security

When an organization leverages the services of a cloud computing provider, the IT infrastructure gets divided between two organizations. Both of these organizations have security requirements that need to be met. This premise might suggest that the costs associated to security would rise, but the cloud service provider will be centralization the services in their data centres for a large number of clients. This situation allows for economy of scale by implementing security measures that serve many organizations at once.

With part of their infrastructure housed and protected by the cloud service provider, organizations have a reduced IT infrastructure footprint and can focus on protecting their end-users and client devices.

Security at the cloud infrastructure

What do security requirements feel like from the perspective of the cloud service provider? Because what they provide is an infrastructure to host their client’s systems, their focus on security occurs at the lower levels of the implementation. Let’s look at some of these levels.

Physical security

An unavoidable aspect of creating a secure infrastructure for their clients is the physical security of the data centre. Although it might appear to customers of “cloud” that this infrastructure is virtual, there must be very real, very tangible data centres at some location, and they must be physically secure.

The following article provide a great overview of the physical security controls used by data centres:

Key Data Center Physical Security Measures

An important part of the physical security of data centres is to ensure continuous power for the computing systems of course, but also for cooling. Data centres consume a lot of power.

Read this article which describes the cooling requirements of a typical cooling centre

Data Center Sustainability

Physical security will also include monitoring, using locked doors, surveillance, guards, motion sensors, and other access controls. By centralizing the physical locations of computer systems, cloud providers create an economy of scale for physical security.

Personnel security

As we saw in the previous module, personnel security is an area of security that focuses on the restriction of human behaviour. Physical security restricts external people from accessing the building and restricts authorized personnel from reaching into physical areas beyond their authorization. Cloud service providers implement personnel security in many ways, but those implementations are not shared with the public. We can assume that there is a level of background

check being performed (these were detailed in the previous module), but mostly it will be provided by granting only the required privileges to onsite personnel, and carefully monitoring their activities towards the system. Later in this module, we will talk about some security concerns that clients of cloud services have towards personnel working in data centres.

Network security

Network security is concerned about the secure transmission of information from one point to another. Since cloud providers cannot manage the Internet, their control ends once data is on public transmission nodes. As with every endpoint online, security must be applied prior to transmission. This usually means verifying the integrity of the endpoint that will receive the information and then applying encryption before sending the transmission.

In some particular cases, it is possible to use dedicated communication lines instead of the public internet. For instance, AWS offers the Direct Connect technology for customers wishing to benefit from a dedicated communication pathway.

Read more about the technology in the following resource:

AWS Direct Connect

IaaS, PaaS, and SaaS

Beyond the security measures that we have covered so far, the rest of the security provisions will depend on what the client is renting from the cloud service provider. There are many levels of services provided by cloud organizations, the main ones being infrastructure as a service (IaaS),

platform as a service (PaaS), and software as a service (SaaS). Each type of service increases the level of responsibility from the cloud provider, including for security provisioning.

Security requirements

Let’s get back to the concept of splitting up the IT infrastructure of an organization between that organization and the cloud service provider, i.e., renting cloud services. Both entities must now assume responsibility for the security of the operations under their control. None of them wishes to suffer a security breach, that much can be easily assumed. The security controls and the deployment of a secure infrastructure must meet the security requirements of each organization. However, wouldn’t there be a direct correlation between the needs of the cloud provider and the needs of the customer? After all, if the cloud provider is hosting the platforms, applications, and data of the customer, they should be able to meet the security requirements of that customer.

Security debt

Quite simply stated, no organization is exactly where they wish to be when it comes to security. As a matter of fact, neither are we as individuals. We undertake activities that bring some risk, and we are conscious of that fact. We accept a level of risk and go forward with our activities. Whether or not it is calculated and carefully assessed, we understand that there is a level of risk and that things can go wrong. For example, if you get into a car and take the road, there are numerous things that could happen that would put you in danger. We still routinely get in cars, buses, Ubers, and all kinds of transportation, sometimes just because we want to take a drive.

Most of us, given a chance, would increase the level of security of the vehicles we get into. Better tires, better brakes, better collision resistance, etc. In other words, if we were asked: “what is the level of risk that you want for this vehicle?”, we would answer “none”. That is actually the sensible answer. We do not “want” risk, we “accept” it as a normal part of performing

activities. You might be thinking about your own vehicle and listing things that you would like to do to improve the security of it, including upgrading the vehicle.

Follow this line of thought into the cloud service industry. Organizations that deploy and maintain their own IT infrastructure know that the security is far from perfect. They can list several things that they would want to do better: patching, monitoring, access control, authentication, etc. So, when a cloud service provider comes along and offer to hosts their IT infrastructure, the demands of the customers regarding security will be towards the security that they want, not the security that they have.

The difference between the security in place and the security that should be in place is called “security debt”. The debt is owed to various constraints, typically time, money, expertise, and people. Several organizations perform audits of their systems and their security and list all the things that need improvement in a document. This is their “to-do” list of security and is basically documenting the security debt of the organization.

Not a unique solution

The security level of an organization is based on the calculated risk that they face while conducting their operations. Lower risk means better security. Risk is assessed using the value of the assets of the organization, the capabilities of attackers to target the assets, and the vulnerabilities that attackers can exploit. Reducing risk usually means introducing security controls that directly reduce or eliminate vulnerabilities. Security debt amounts to the vulnerabilities that have not been mitigated.

There is not a “one-size-fits-all” solution for security. Different organizations will have different needs based on who they are. It’s not just a question of preference, but of the reality of the factors that determine risk. Different organizations deal with different types of assets. Different types of assets can attract a different calibre of threat actors.

Needs for security tailoring

As you can understand, although every organization may wish for perfect security, it is not feasible nor practical to deploy it. One method of assessment to determine if security is sufficient is to compare the cost of breaching security to the potential gain that could be achieved by the threat actors. If the cost of breaching the system is high enough, then the target is not profitable. However, that calculation works best for cases where the motivation of the attackers is financial. If the attackers are motivated by ideology, revenge, or self-preservation it can be very difficult to understand the lengths that they would go to.

Myths about cloud security

In this section, we will look at some of the myths that surround cloud security, and analyze what customers are weary about when it comes to putting their data on cloud infrastructure.

Cloud Security: 12 Myths vs Facts

The next sections will review the myths stated in the article and add depth to the explanations provided.

MYTH #1: THE MORE SECURITY TOOLS YOU HAVE, THE BETTER

As stated in the article, just throwing security tools one on top of the other may only serve to complicate the system. Security needs to be carefully designed and deployed to address real vulnerabilities without leaving opportunities. Security design is more about a culture and adopting a posture of security. The tools serve that posture, they cannot replace it.

There is a common wisdom that states: security hates complexity. Basically, to provide good security to a system, you need to understand everything it does and how security controls are protecting these activities. As the article stated, cloud endpoints can be protected by upwards of 100 security controls, which make the security analysis a momentous task.

MYTH #2: SECURITY IS THE CLOUD PROVIDER’S RESPONSIBILITY

As we already discussed, the level of responsibility for securing the infrastructure will depend on the type of service, but there will always remain a level of security that falls onto the customer to provide. This is defined as the “shared responsibility model” that the article refers to.

MYTH #3: SUCCESSFUL BREACHES RESULT FROM SOPHISTICATED ATTACKS

Threat actors come in a variety of skill levels and sophistications. One easy observation to make is that unsophisticated threat actors will outnumber the sophisticated ones quite significantly. This means that there is a much higher likelihood that a non-sophisticated attacker will target you than a sophisticated one. However, some experts believe that we should focus more on the sophistication of the attack methodology, not the potential sophistication of the attacker. It is true that even a sophisticated attacker will use unsophisticated methodology when possible. This lowers the cost of the attack and creates difficulty to identify the perpetrators since unsophisticated methodology is available to any attacker. It goes back to a previous statement: make the attack costly for the threat actor, so that they must use sophisticated means to break in. When the cost outweighs the benefits, breaking in is no longer interesting.

MYTH #4: CLOUD VISIBILITY IS EASY

Visibility is essential in any system deployment. It is at the heart of monitoring. While many security controls are preventive in nature, monitoring is at the center of efforts regarding detection, analysis, containment, eradication, and recovery. We will discuss incident handling later in this course with much more details, but for now keep in mind that reducing the impact of an incident, security or otherwise, has a lot to do with early detection.

MYTH #5: SECURITY IS BEST LEFT TO SECURITY PROS

Especially when it comes to development, testing, and securing IT systems, security cannot solely rely on security professionals. In DevSecOps for instance, it is recommended to transfer some of the responsibility for security to the developers, and elect security champions that will facilitate the communication between the development team, the testers, and the security professionals. Security, as stated before, is more a question of culture throughout the organization, and everyone should collaborate to enhancing the overall security posture.

MYTH #6: THE CLOUD IS INHERENTLY MORE SECURE

This is an ongoing debate between security experts, and as the article stated there is some truth behind the statement. To get a better sense of the question, think back to the notion of security debt. Who has more debt towards their security? Cloud providers or client organizations? There is no way to answer that because it will vary between cloud providers and between organizations.

For an organization considering a move to the cloud, it can be stressful to relinquish control over certain aspects of the infrastructure to a third-party provider. Organizations will consider the security aspects of the cloud providers against where they want to be, not where they currently stand. In other words, they are going to want the cloud security to wipe out their security debt. Security practitioners in the organization may better understand the actual gain or loss in security that is likely to happen following the potential migration.

MYTH #7: YOU MUST SLOW DOWN DEVELOPERS TO BE SECURE

As already covered, transferring security concerns to non-security practitioners, especially in a DevOps approach, makes a lot of sense. This approach was highly debated for a long time before statistical data was made available that showed the benefits of a tighter cohesion between development, operations, and security.

MYTH #8: SECURITY AUTOMATION IS IDEAL, RENDERING HUMAN OVERSIGHT ARCHAIC AND UNNECESSARY

In cloud security, as in many other areas of the IT world, the introduction of large-scale systems powered by artificial intelligence and machine learning may render human intervention meaningless. After all, cloud is built upon automation, so why shouldn't its security rely on it as well? The answer for now is that automation can provide a lot to security, but there are still things that humans are better equipped to do than machines. The ideal solution may lie somewhere in between, where knowledgeable humans increase their capacity through automation. This is what IT has always been about.

MYTH #9: SECURITY OF SAAS APPS IS MANAGED BY THE SAAS PROVIDER & REQUIRES NONE OF YOUR ATTENTION

SaaS might be a type of service where security mostly falls onto the provider's responsibility, but the shared responsibility model still applies. Systems like Office 365 are an example of SaaS where even though the security is applied by the vendor, clients

must be cautious with credentials, leverage two-factor authentication when relevant, manage the sharing of documents, and report incidents when they occur.

MYTH #10: S3 BUCKETS ARE SECURE BY DEFAULT

Definitely a myth, as evidenced by the string of breaches owing to nothing more than a misconfigured S3 bucket.

This myth is not against S3 buckets. As the article states, they are closed off by default, and only the owner will access them until privileges are granted. It illustrates the need for human overview into security. How can automation tell you that a bucket is misconfigured? How can automation know that the settings are too permissive? It reinforces the notion that humans are still an essential part of the security equation.

MYTH #11: CONTAINERS AND SERVERLESS FUNCTIONS ARE INHERENTLY MORE SECURE

Containers and serverless functions are designed to reduce overhead, require less resources to function, and be deployable with less compatibility issues. They are not designed to increase security, and neither will they on their own. They need to be secured, tested, and configured properly to only allow authorized access and use.

MYTH #12: CVE'S ARE THE ONLY VULNERABILITIES I NEED TO CARE ABOUT

CVE stands for "Common Vulnerabilities and Exposures". They are basically a communication system to inform the general cyber community about discovered vulnerabilities and how to fix them. You can learn more about them at this website:

CVE

Any security expert can tell you what the problem is with the belief that we can limit ourselves only to the CVE information. CVEs are about what is referred to as "public" software. Software that is deployed in publicly accessible applications, whether on operating systems, industrial controls systems, browsers, network firmware, or any other type of application. There are no CVEs for private software, i.e., software developed and used by an organization. The security of internal software will be a responsibility of the organization that is using it. And even though CVE may inform about known vulnerabilities in dependencies, this still leaves behind custom code and custom configurations.

Overview

Cloud is still very new, even though it is quickly becoming an unavoidable aspect of IT deployment. Cloud service providers have made themselves an attractive proposition for the trusted delivery of IT services at a lower cost. The question of security is only one aspect that concerns potential adopters of cloud services.

Module 3 | Privacy and confidentiality

Confidentiality limits access to information; privacy concerns personal information and an individual's ability to control its exposure. Cloud services can support strong protection, but broad internet access and configuration errors can expose data quickly.

Threats can come from insiders, providers, external attackers, weak authentication, excessive permissions, unpatched software, and insecure configuration. Strong, unique credentials, multifactor authentication, encryption, access controls, and monitoring work together.

Front-end data access: Access through the application's normal accounts, permissions, and controls. **Back-end data access:** Direct access to infrastructure or stored data that bypasses normal application access controls and monitoring.

Privacy and confidentiality

The notions of privacy and confidentiality may seem interchangeable, but they're not. Confidentiality is about protecting secrets. These secrets may relate to business operations, intellectual properties, and client information. Privacy is about shielding oneself from the public eye. It relates to personal information that we may wish to keep private. There is an overlap between confidentiality and privacy, and both concepts boil down to allowing only authorized individuals to access the information. For example, you may consider your personal health information to be private, but you will reveal it to a physician attending to your

care. Note that this physician will be under strict regulations to protect the privacy of that information and you must feel confident that the information will be adequately guarded from prying eyes.

The concepts of privacy and confidentiality meet when service providers collect, process, and store the private information of their clients. Nowadays, with the digitization of services, this information will be handled electronically. An organization must then be able to protect the privacy of its client's data by protecting the confidentiality of its operations.

This article provides an in-depth analysis of the notions of confidentiality and privacy.

privacy-vs-confidentiality

Evolving exposure of the information

Not very long ago, organizations still mostly relied on physical documents, stored locally in the building's archive section. The security was physical as well. Clients would provide information using pen and paper and handed it directly to the service provider. Concerns were largely about who could access the archives and see the data.

As information technology (IT) made its way into office buildings, information was less and less a matter of physical documentation and became a digital asset. The attractiveness of using IT when compared to physical archives was tremendous, as we already covered in the first module. The protection of the archives became a matter of IT security: granting accounts, access, and privileges only to authorized individuals. However, since the IT equipment was in-house, cyber attacks were not the main threat at that point.

With the evolution of cloud computing technology, many organizations are now placing their confidential information, including the private information of their customers in some cases, on cloud platforms that are highly accessible. After all, accessibility is a key aspect of cloud computing, and putting the information "in the cloud" exposes it to all sorts of cyber attacks.

One of the key concepts for this module is the notion of exposure. What are the threats to which our data is exposed when it comes to the confidentiality of the information? From physical documentation stored in-house in the past, to a centralized and public cloud infrastructure, we can easily see that this exposure has increased tremendously over time.

Is cloud bad for privacy?

Is the use of cloud computing inherently bad for privacy? It is a relevant question to ask when considering the confidentiality provided by cloud infrastructure. After all, cloud increases the exposure of the information and may indeed facilitate cyber attacks on confidential information. Mistakes in access controls and configuration that would have been rather benign when data was stored in-house can be absolutely disastrous when they occur on a cloud infrastructure.

Trends in cyber attacks

The laws in Canada concerning breaches of private information were amended in 2018 to make it mandatory for organization to publicly disclose those breaches. Before, companies were tempted to dissimulate the attacks to protect their reputation and the trust of their customers and partners. When reporting became mandatory, the numbers jumped up significantly. Ever since, the numbers are more reliable and can be used to observe trends about cybercrime.

Canada and Canadians are routinely victims of cybercrime. Statistics published in 2023 indicated that over half of Canadians have experienced cybercrime at least once. It also highlighted that Canada saw a large increase in the number of companies that were hit by cyber attacks, going from 78% in 2020, to 85.7% in the following year.

Find out more statistics at the following link:

Cyber Crime Statistics In Canada

What about the trend in cloud adoption? According to Deloitte, the adoption of cloud by Canadian companies has outpaced expectations and reached over half of all enterprise computing by the end of 2021. Many companies that were reluctant to move to cloud have finally decided to migrate their infrastructure to cloud. Of the factors that explain this migration is the pressure created by the pandemic to move to a distributed model.

For a detailed analysis on cloud adoption, consult the following article from CPA:

'Cloud adoption is expected to continue at a torrid pace

A quick realization is that cloud adoption and cyber attacks are both increasing at higher rates than expected. More information would be needed to determine if there is a link between these two trends, but an educated guess would suggest that a rushed cloud adoption, as many organizations were forced to do to maintain operations during the pandemic, created the opportunity for attackers to breach organizations now being exposed on cloud infrastructure.

Threats to confidentiality

Whether on a cloud platform or not, there are many potential threats to the confidentiality of information. In this section, we will discuss what these threats are in general, and how they can manifest against information systems.

Insider threats

As we said before, confidentiality is about allowing only authorized individuals to access the information. We would assume that authorized individuals are legitimate users, employees, and administrators, and that unauthorized users are the ones trying to get in and compromise the data, basically hackers and cybercriminals.

However, there are threats that find themselves in-between these two distinct categories. Insider threats refer to individuals that access data beyond their authorization. They are individuals that have been granted some access to, or knowledge about, the system and they use that access to breach the system. Recall the example of the physician that has access to your data. That person is authorized to see the information, but if they post some information about your health on their Facebook page, they would be going above their authorization and be seen as an insider threat. It can be very difficult to deal with insider threats, and the occurrence of data breaches associated to insider threats is higher than we typically think it would be.

Notice that insider threats are not a cloud issue, or even an IT issue. Any time when someone is entrusted with access to confidential information is a situation that could lead to a breach of this trust and an insider threat situation. That being said, it is true that IT has exacerbated the insider threat situation. After all, it is easier to compromise electronic information than paper information. Copying electronic files is very quick, and taking the information out of the building can be very inconspicuous. The organization victim of an insider threat breach may not realize it for a very long time. The most well-known insider threat, Edward Snowden, managed to steal a tremendous amount of very sensitive information from a highly secure environment. This is further proof that limiting the risk of insider threats can be a very daunting task for any organization.

This article offers some details and speculation about the massive breach conducted by Edward Snowden against the NSA.

Deciphering How Edward Snowden Breached the NSA [8

Cloud service providers and insider threats

When considering a migration to a cloud infrastructure, organizations worry about the risk of insider threats that could occur from the cloud provider, in addition to their own insider threat risk. This is because the services of a cloud provider are very unique: it basically requires that organizations take their corporate, arguably their most valuable asset, and entrust an external corporation to host it and protect it. The security risk from insider threat is not only real, but faceless and impossible to assess. Organizations have very little insight into the security management processes occurring at the cloud provider's data centres yet is being asked to trust them. The rationale from organization is that they can log access to data, place access controls, grant and revoke privileges and accounts, but this front-end management. Organizations worry about back-end access to data that cloud personnel will have once the data is in their data centres. Back-end access can bypass restrictions, account limitations, and evade surveillance completely.

In response to those concerns, Microsoft published a document titled "How does Microsoft handle your data in the cloud?". The white paper discusses the notion of "subprocessors": basically, subcontractors that perform work on behalf of Microsoft on their cloud infrastructure.

You can consult the whitepaper at the following link:

How does Microsoft handle your data in the cloud?

These tasks can include applying patches, configuring and deploying hardware, and anything else that Microsoft would require. Let's see what Microsoft says about the possibility of insider threat in that document.

Microsoft states the following on page 3 of the document:

“While all the subprocessors included on the list have the potential to access customer data or personal data (or both), in practice, the actual access to data is much less. In many cases, the data is pseudonymized and the vendor personnel do their work without ever needing to access nonanonymized data. In other cases, the tasks the vendor personnel perform do not themselves require access to data, but they technically have potential to do so.”

Not necessarily reassuring. We understand that subprocessors may not need to access the data, neither are they authorized to do so, but that is not the concern for insider threat. The concern is whether they can. And on that point, Microsoft clearly states that this is the case.

Right after that statement, the document follows up with this:

“In a highly secure, access-controlled environment, subprocessors may have the potential to access restricted data such as customer and/or personal data specifically to deliver functions in support of online services that Microsoft has hired them to provide, and they are prohibited from using this data for any other purpose.”

This statement is more of the same. Does it alleviate the concern for insider threat? No, not at all. It merely states that Microsoft does not allow the subprocessors to breach their client’s data. We would expect as much. Customers want to see actual restrictions being applied on subprocessors that limit or remove the risk from insider access.

External threat actors

External threat actors refer to the broad category of attackers that wish to compromise an organization for their own gain and profit. They do not benefit from internal access or knowledge and are typically attacking through the Internet. If it wasn’t for hackers, the mistakes that people make while handling the systems would not matter as much. But with the intensity and persistence that hackers display when targeting online systems, any type of mistake will be exploited by these threat actors.

The general public’s conception of what a hacker is and how they operate, a potential side effect of the Hollywood portrayal of hackers, is entirely wrong in most cases. Rather than being geniuses that penetrate well guarded systems at ease, most hackers by far have little to no skill, and are looking for easy entry into systems. When that is not available, they will move on to another system that offers less resistance. Their methods are for the most part very basic, and even more advanced hackers usually rely on simple tactics to gain intrusion into systems. What that means, is that basic cyber security can go a long way into protecting the information from hackers.

In the next section, we will go over some of the common ways that hackers breach online systems.

Commonly exploited vulnerabilities

While it is true that sophisticated hackers can craft advanced cyber weaponry, there’s a small number of hackers with the capacity to do so, and the vast majority of breaches are due to much less sophisticated techniques. In this section, we look at some of the commonly exploited vulnerabilities in online systems.

Authentication weaknesses

As we discussed previously, cloud systems offer higher accessibility and usability than internal systems. For some types of applications, this is a requirement. For instance, if you host a web application for various clients, having a visible and accessible online presence will be part of the design.

The authentication vulnerabilities that can be exploited are numerous, and in many cases not well understood from the clients nor the service providers. On the side of the clients, people tend to use predictable passwords, and reuse the same passwords over many different systems. This creates an easily exploitable vulnerability because a breach to one system will often reveal combinations of usernames (often an email address) and passwords that can be stuffed into other applications with the hope of breaching those systems. This approach is known as credential stuffing, and with some simple automation tools becomes an easy yet devastating attack.

Configuration issues

As we covered in a previous module, configuration issues plague cloud solutions. It is easy to misconfigure access controls, services, monitoring, and other aspects of a cloud deployment. The cloud service provider will also be limited in the assistance that they can provide to their customers regarding configuration. After all, settings and configurations are about the client defining their parameters and protocols to meet their requirements. The cloud service provider should make it easy to do for

authorized individuals to define these settings, and arguably they do this to a great extent, and facilitate the monitor of these settings, which they also do.

Misconfigured services can mean that access is too permissive, that unauthorized actions will not be detected, that aspects of the system will be available to unauthorized individuals, or that error messages will provide too much information to the end user. All of these things can be leveraged by an external threat actor to breach the online systems.

Unpatched vulnerabilities

Very capable threat actors will analyze systems, uncover hidden vulnerabilities, create cyber weapons from these vulnerabilities, and become able to take down systems in a very sophisticated manner that leaves very little opportunities to system owners to defend themselves. These vulnerabilities are known as “zero-day vulnerabilities”, and the associated exploits are called “zeroday weapons”. They are a nightmare for service providers because they are notoriously difficult to defend against.

While it is true that zero-day weapons exist, they cause a relatively small number of breaches. This is because they are costly and difficult to create, require a lot of skill, knowledge, and work, and are usually reserved for high-calibre targets.

However, there is a correlation between zero-day weapons and attacks of lower sophistications. After a zero-day weapon starts being used, the defenders identify the vulnerabilities being exploited, design patches to fix the systems, and the patches are deployed to the general public for the systems to be fixed. But, unfortunately, maintaining the patching level of systems up to date is a difficult task. Systems are complex, full of dependencies and third parties, and administrators struggle with just knowing which systems need to be patched and how. There are tremendous efforts invested towards the facilitation and automation of patching. Still, a tremendous amount of work needs to be done. It does not require any skill for a hacker to exploit an unpatched vulnerability. Some of them can be exploited remotely, with little risk and tremendous impact.

The Apache Log4J exploit was, and still is, extremely damaging: the vulnerability was widespread and attackers managed to easily exploit several systems. Watch the following reporting on the exploit:

Protecting confidentiality

Improving general cyber security measures will contribute to protecting confidentiality and privacy. In this section, we will list some of the tools that can be added to this posture to target specifically the protection of confidential and private information stored in online systems.

Strong authentication

Unsurprisingly, protecting the authentication measures will be a must for the protection of confidentiality and other attributes of information. However, there might be some misconception about what constitutes a “strong” authentication.

Strong authentication is about the work factor involved in defeating the authentication method. Defeating the mechanism means that an unauthorized individual is recognized as legitimate by the system. The more difficult this is to do for an attacker, the more robust the authentication mechanism.

Passwords can be a decently strong authentication mechanism, but only on the condition that the password used is unpredictable, random, and unique to each account. For most people, this will be impossible to manage without the help of a password manager solution.

Most experts would recommend supplementing passwords with a second factor of authentication, like an authenticator app, a biometric reading, or other secondary factors. There are many solutions that exist, and even a medium strength secondary factor will be much better than none.

Data encryption

Another security control that can increase the protection of confidentiality is the judicious use of data encryption. There are two ways to apply encryption: to data while it travels on the network (data in transit), and when data is stored in information systems (data at rest).

Data encryption is not always the solution that people expect that it will be. This is because the use of encryption does not equal the removal of the problem, only to reduce it and make it more manageable. What this means is that when faced with protecting the confidentiality of a large amount of data, the problem can be very complex. By applying encryption to the data, the problem

now shifts towards protecting a small amount of data: the encryption key. This can still be quite a daunting task, because it will involve generating the key, exchanging it, storing it, and preparing for

a loss of the key or its compromise. There is also an implicit trust of the encryption algorithms being used. Although not typically an issue, it has become a concern with the looming threat of strong quantum computing.

The following article details the threat of quantum computing for current methods of encryption:

Quantum computers can break major encryption metho

Access controls

Because confidentiality is defined as only allowing authorized individuals to access information, one of the main tools when it comes to protecting confidentiality is the proper implementation of accounts, roles, privileges, and permissions. This is the basic implementation of access controls to define the permissions. Throughout the course, we will explore various ways to define users, groups, and roles and how to apply proper permissions to them.

Module 4 | Integrity and authenticity

Integrity means information and systems are accurate, complete, and unaltered in unauthorized ways. Authenticity means an entity, message, or file is genuinely what it claims to be. These properties are essential when a trusted update, certificate, or account could be impersonated.

Hashes detect changes; digital signatures bind a signer to content using asymmetric cryptography. Certificates and a chain of trust help a browser assess a web server's identity. The certificate walkthrough shows how these ideas appear in an HTTPS connection.

Symmetric encryption: Encryption and decryption using the same secret key. **Asymmetric cryptography:** Cryptography using related public and private keys. **Digital signature:** A signature tied to both content and a signer, created using hashing and a private key.

Integrity and authenticity

When we discussed confidentiality in the previous module, we defined it as protecting information from unauthorized access, basically preventing someone who is not supposed to from reading the information. When it comes to integrity, the requirement is often described as preventing unauthorized people from modifying the information. However, it can be a bit subtler and more nuanced than this. In this module, you will learn about aspects of integrity and authenticity for information systems.

Definition of the concepts

Integrity of information can be defined as being able to trust that the information is accurate, complete, and unaltered. In other words, we can trust that the data is what it is supposed to be. And yes, that does include that the data has not been modified by unauthorized individuals.

In essence, integrity is about trust: trusting that the hardware, software, networks, data, and entities that we interact with are what they are supposed to be.

In that optic, what is authenticity? Authenticity and integrity are closely related but they are not the same thing. Integrity is about trusting the information and infrastructure, and authenticity is the level of assurance that we have towards the integrity. In other words, what is providing the trust that we have? Why can we state that the information is accurate?

Examples of scenarios

It is quite possible that the main threat to information systems are not breaches of confidentiality but instead breaches to integrity. What is sometimes depicted as an integrity breach, like passwords being stolen, could be more accurately described as a breach of integrity.

What happens if someone steal the credentials to your bank account? Nothing really if the person does not use them, because your credentials are not "information". The password itself is meaningless. However, if the hacker uses your credentials to log in,

what happens? The bank will mistakenly let the attacker in, thinking that it is you. This is a breach of integrity to the session being created in the bank's systems. Then, the hacker could look at your data, another action with limited consequences in itself. However, real damage will occur if the hacker uses the data to commit transactions, ask for loans, redirect funds, etc. Those are integrity breaches are because the transactions are not what they appear to be.

What happens if you download a pirated video game that was corrupted with malware? You will install the game along with the malware onto your computer, and a threat actor will likely be able to gain access to your network and compromise your device. What the hacker will do can vary, but we could expect using your computer to hack your contacts by pretending to be you, stealing your credit card information to do purchases in your name, etc. This sequence of events is one breach of integrity after another. The game is not what it is supposed to be and is corrupted with malware. The corruption spreads to your computer, which is not trustworthy anymore after being corrupted with malware. If the hacker then attacks your contacts by pretending to be you, the emails received by those contacts do not have integrity because they are not what they appear to be. The list goes on.

Importance of information system integrity

As you can see, integrity is a very important concern in today's world. Our transactions are conducted online instead of in-person, and validating that the networks, servers, and people we are interacting with are the actual entities that we believe they are can be a very difficult challenge. Even the simple act of receiving an email is a risky endeavour. We train people to be cautious and suspicious, to inspect the components of the email, to validate the sources and content, etc. Providing an adequate level of assurance, i.e., the authenticity of the components is an ongoing struggle.

In the next section, we will look at some of the recent cases where integrity breaches caused a lot of damage to information systems.

Breaches to integrity

The Internet is a global communication network where users interact with online entities to obtain services. As we saw in the previous module, protecting the secrecy of the data exchanged and stored when these transactions occur is an important facet of cyber security, but what about the integrity? In this section, we look at recent events that place the spotlight on our struggle to validate the authenticity of information.

SolarWinds

SolarWinds is a software provider, and in 2020 they were hacked by a sophisticated threat actor. The attacker managed to inject malware into a software update for one of its products: Orion. The update was sent to thousands of clients of the company, including highly sensitive government agency networks, where it provided the hackers with remote access to the victims' networks.

Here, we can see the concepts of integrity and authenticity at play. The integrity of the software update was breached. The clients, not knowing this, downloaded the update into their network. If we would have asked the clients what the authenticity of the patch was, i.e., the level of assurance they had that the patch was trustworthy, they would have probably stated that:

• It came directly from the software maker.

• It was distributed to all the clients at the same time.

• They would also have been able to validate that the update was exactly what the software provider sent to them (a verification automated via digital signatures, as will be explored later).

In other words, even though the update was corrupted and tampered with, the authenticity of the file was high.

The SolarWinds breach has now become synonymous with supply chain ompromise. Read more details about the SolarWinds breach here.

SolarWinds Orion: More US government agencies hack

Canada Revenue Agency

Also in 2020, the Canada Revenue Agency (CRA) suffered a breach to its online services that impacted thousands of clients. The attack used two of the commonly exploited vulnerabilities that we explored in the previous module: credential stuffing and

system misconfiguration. Through the combination of these two vulnerabilities, hackers got access to thousands of accounts of CRA customers.

The use of previously exposed credentials allowed hackers to log into users' accounts, and the misconfiguration allowed the hackers to bypass security questions. The intrusions led to several integrity breaches. Cybercriminals modified the profiles, putting different email addresses and modifying the bank account numbers in the accounts. They created fraudulent requests on behalf of the users.

The following article provides details about the breach. One of the targets of the threat actors was the Canada Emergency Response Benefit which made funds available to Canadian households harshly impacted by the pandemic:

CRA shuts down online services after thousands of acco

In this example as in the previous one, the actual repercussion of the attack is very difficult to assess. There could be occurrences of identity theft for years to come in relation to the incident. Certainly, funds that were made available to needful Canadians were lost to criminals. There may be some profiles that were fraudulently modified that haven't yet been identified.

Confidentiality and integrity

You may have gotten the impression that confidentiality and integrity are actually closely related, and you would be correct in that assumption. Confidentiality breaches lead to integrity breaches, which lead to confidentiality breaches, etc. Several of the security mechanisms that protect confidentiality, such as robust authentication, patching, and configuration will also be good security measures for the protection of integrity.

In the next section, we will look at security control that apply more specifically to protecting the integrity of information and infrastructure.

Security controls for integrity and authenticity

There are security controls that are especially meant for the protection of integrity, i.e., to increase the authenticity of files, entities, and communications over a network. The main control involved in information integrity is a digital signature. In order to clearly understand how digital signatures work, we will look at all the underlying principles of digital signatures in this section.

Asymmetric cryptography

At the root of digital signatures is the concept of asymmetric cryptography. The name highlights the contrast with symmetric cryptography. With symmetric cryptography, encryption and decryption are performed using the same key. Symmetric encryption is used to protect the confidentiality of information, in transit or at rest. It requires that the key is made available at both ends of the transaction.

Asymmetric cryptography, on the other hand, is a very different concept. It uses mathematical processes to allow encryption and decryption to be done using two different, albeit related, keys. One key is made public, and the other key is kept private. Hence, an entity will have a pair of keys. The keys work asymmetrically, meaning that what is encrypted with a key can only be encrypted with the other related key.

Imagine that you are defining yourself as an entity on the Internet. You are generating a pair of keys, one private and one public. You keep the private key with you, well protected. The public key is readily available to whomever wants to use it. Now, let's look at the two basic transactions that can occur.

Protecting confidentiality

If someone wants to send you information with confidentiality, they can grab your public key and use it to encrypt the data they want to protect. The only key that will be able to decrypt the information then will be the private key, which only you have access to. It effectively protects the confidentiality of the information through this simple process.

Notice that if the public key is placed on a public website, like a blog, it allows anybody to engage in this confidential communication. This is the basic principle that allows us to reach out to entities such as web server and create an encrypted communication out of the blue.

Protecting integrity and authenticity

As mentioned before, asymmetric cryptography uses two related keys. What is encrypted with one key can only be decrypted with the other key. We already saw how that can be used to protect the confidentiality of a communication by using the public key to encrypt data, thus ensuring that the private key must be used for the decryption.

But what about using the private key to encrypt? When doing so, an entity would encrypt data with its own private key, and only the public key would be able to decrypt the data. You might wonder what the point of that would be, since everybody has access to the public key, and they could use it to decrypt the data. The scheme does not provide any confidentiality. However, the process does provide authenticity. This is because if the data can be decrypted using the public key of the entity, it validates that the content had to have been encrypted with the private key. On the assumption that the private key was not breached, it determines that the data does indeed come from the entity. It is a security control to protect integrity and forms the basis of what we refer to as a digital signature.

Uses of a digital signature

There are many cases where confidentiality is not a requirement, but where integrity is required. For example, when a software patch is delivered, it does not require secrecy: it is broadly distributed. However, its recipients need to validate the integrity of the patch before they apply it. If the patch is encrypted with the private key of the software distributor, i.e., the patch can be decrypted with the distributor's public key. It provides a higher level of authenticity to the software patch. In practice, this is not exactly how the process is conducted. A digital signature is created by encrypting the hash value of the file. The hash value is a small "fingerprint" generated from the file that is unique to the file. Encrypting the fingerprint provides the same level of assurance as encrypting the file, but the hash value is much smaller and easier to manage.

Digital signatures are commonly used today to provide integrity to documents, like electronic contracts. It's also how we can identify entities online like web servers and email servers with a higher level of assurance.

Digital signatures in cloud infrastructure

Digital signatures are commonly used in cloud infrastructure. They are used to remotely log into remote servers. Using a digital signature is an effective mechanism to provide authentication. Digital signatures are used with certificates of authenticity in order to identify servers before establishing a connection. When virtual machines are updated, the updates must have digital signatures on them to be trusted.

As you can see, it would not be possible to use the Internet the way that we do today without the extensive use of asymmetric encryption and digital signatures. The next section will allow you to look at the mechanics of the system.

Analysis

Certificate and HTTPS walkthrough

The Algonquin College website is used as an example of an HTTPS connection. HTTPS encrypts communication and uses a certificate to help the browser assess the identity of the web server. A padlock in the address bar indicates that the browser has established a secure connection.

Certificate details identify the subject, the certificate issuer or certification authority (CA), the validity period, and the domain names covered. The example certificate named Algonquin College of Applied Arts and Technology and showed GlobalSign as its issuer. Certificate names, issuers, and dates can change when a certificate is renewed.

A certificate chain connects the site certificate to an intermediate CA and then to a trusted root CA. The browser relies on this chain, the CA's identity checks, sound cryptography, and protection of private keys when deciding whether to trust a site.

The certificate also contains the site public key and fingerprints, which are hash values of the certificate. A digital signature provides assurance about the integrity of content and its source. It does not, by itself, keep data confidential; encryption provides confidentiality.

Case study

The source notes point to a 2023 Microsoft/Azure signing-key breach as an example of a failure in the chain of trust. If attackers obtain a private signing key, they can create signatures that appear to come from the legitimate signer. This illustrates why private-key protection is essential to authenticity and integrity.

Module 5 | Availability and resilience

Availability means authorized users can use systems and information when needed. A service can be unavailable through overload, hardware failure, malicious attacks, or dependencies outside the application itself.

Resilience combines capacity planning, load balancing, redundancy, distribution, recovery, and protection against ransomware and denial-of-service attacks. A CDN places content nearer to users and spreads demand across locations.

Uptime / downtime: Time a system is available / unavailable; availability is often reported as an uptime percentage. **Botnet:** A group of controlled Internet-connected devices that can be used for attacks such as DDoS. **DDoS:** Distributed denial of service: many sources overwhelm a service or its network resources. **Hacktivism:** Use of computer-based attacks or techniques to advance a political or social cause.

Availability requirements

As we saw in previous modules, protecting our data and our infrastructure can be brought down to the protection of three essential attributes: confidentiality, integrity, and availability. Those three attributes are often referred to as the CIA triad in security. After having covered confidentiality requirements and integrity measures in the previous modules, we are now discussing notions of availability in cloud deployed environments.

What is availability

The notion of availability in information security might seem out of place, since many people see this as an operational constraint more than anything else. However, availability failures can result in injury to the organization and its customers, and there are security angles to consider when deploying controls to protect availability.

A formal definition of availability from a security perspective is to say that availability is “the capacity to use systems and information in a timely manner”. This definition is flexible and can adapt to various scenarios, and that makes sense because ensuring availability can be a costly proposition. Not all systems requiring the same degree of availability, hence the terminology “in a timely manner”. For example, an air traffic controller depending on available data to direct air traffic will have a much higher requirement for availability than an online store for arts and craft. However, it is true that they would both wish for their systems to be continuously available. How much they are willing to pay for that privilege will vary a lot.

How to calculate availability

When discussing matters of availability, a term that comes up a lot, to the point where it is almost synonymous with availability, is uptime. Uptime is the opposite of downtime, a situation where the systems are not available because of failure or maintenance. Uptime is often expressed as a percentage. For instance, if a system has 99% uptime, that means that for a given year, the accumulated downtime cannot exceed 1% of the year, i.e., 3.65 days or about 88 hours.

Some systems promise high availability, which is up to 99.999% uptime, referred to as “five nines” or less than 5 minutes and 15 seconds of downtime per year. High availability is expensive and will be applied for systems that are critical: emergency services, air traffic control, communications infrastructure, etc.

Cloud service providers create the underlying infrastructure for many systems that will require high availability, and as such the cloud data centers themselves will require high availability. Of course, the goal is “no downtime”, or an “always-on” system. When things do go wrong, incident management will provide the capacity to maintain operations and restore functionality.

Service level agreements

As mentioned, not all services deployed over cloud require the same uptime. Organizations must establish their own requirement, as they would for confidentiality and integrity, and leverage the services of the cloud service provider in order to

meet those requirements.

However, as opposed to confidentiality and integrity, the client is not able to manage availability on its own. For instance, the client can deploy its own protocols for access controls, encryption, digital signatures, and by doing so manage a large amount of the work required for confidentiality and integrity, using the cloud merely as a distribution platform. But, if the cloud suffers downtime, the client's operations will go down, no matter what they do. In that sense, availability starts with the cloud provider, and depends largely upon it for the operational capacity.

Because of this, the client and the cloud provider will have to define their needs for "guaranteed uptime". This will be part of the Service Level Agreements defined in the contractual obligations between the client and the cloud provider. Obviously, the higher the requirement for uptime, the

costlier the contract.

Threats to availability

Before we get into the mechanisms to protect availability, let's discuss some of the threats that online systems face that can bring them down. Knowing about the threats helps to better understand how the security tools and various other controls that protect availability work.

We will look at some of the main threats against availability in the rest of this section.

Service capacity

When deploying an online system, it depends on the computers that run that system to function. Those computers have limited capacity: microprocessor can only do a certain number of operations per second, volatile memory can get overloaded, storage space can be depleted, and so forth. Computers have developed tremendously in the last couple of decades and are now capable of handling large loads of requests. Nevertheless, there is always a limit to what a system can handle.

Determining how much a system can handle is called "stress testing". Administrators artificially induce an increasing number of requests to the system and monitor its performance. Stress testing can help to understand the capacity of the system, and better now what to expect when the system is under duress in production environments. Stress testing can also point out the existence of stress points in the system, i.e., parts of the system that might fail first while the rest of the system is still able to increase the workload. For example, if the CPU capacity is reached first and causes the system to slow down or even fail, it is a clear indicator that the system may need additional CPU cores to increase its capacity.

Determining how much capacity the system should possess is not an easy task. It relies on assumptions as to the number of requests and is not a static target in any case. Some systems have periods of increased demand, such as the holidays for online shopping, or tax season for revenue services. The capacity of the system may need to be periodically increased to meet the demand for the high seasons, as per the elasticity and on-demand provisioning principles of cloud computing.

Mechanical failures

Hardware is not infallible, and when it experiences malfunction or breakdown, it can put the entire system out of commission. The main option to be resilient against mechanical failures is redundancy, as we will explore later. Organizations have learned that relying on equipment can be very risky and will typically set up backup systems to ensure continuity of operations when mechanical failure occurs, or at least limit the downtime that will occur. With cloud computing, the hardware resides in the data centres and is managed by the provider.

The implementation of cloud services is inherently resilient against hardware failures because the system takes it resources from an available pool of resources automatically.

Can a cloud catch on fire? Apparently so.

Water leak at Paris Global Switch data center causes fir

Attacks against availability

In the list of threats to availability are, of course, malicious attacks conducted against online systems with the express purpose of damaging their availability. There are two main types of attacks in this category: ransomware and DDoS attacks.

Ransomware

Ransomware attacks are a major concern in the world of cyber security today. The basis of the attack consists of a cyber criminal managing to infiltrate the target's online systems and encrypting the operational data with a special type of malware called ransomware. The encryption process will try to reach into all the available data, including backup data in some cases. What cyber criminals have understood is that stealing data to sell it back is limited in how monetizable it can be. It requires shopping for buyers and taking a lot of risk and is not always guaranteed to fetch a high reward. On the other hand, the organization that depends on that data for its operational capacity will always see value to it.

Ransomware is basically stealing one's data and selling it back to them. Only, it's even easier for the attacker because they don't need to get the data out, they merely have to encrypt it in place, and they get the same result. When the data is encrypted, productivity stops, and it puts a lot of pressure on the organization to quickly resume normal operations. They can try to figure out what happened and hope to restore from backup, but that takes time and effort, and provides no guarantee. The alternative, which means paying the ransom to cyber criminals, can be cheaper and easier to do. Many organizations cave in and pay the ransom to get back to normal as quickly as possible, and therefore finance gangs of cyber criminals that are becoming extremely dangerous. The gangs reinvest some of the ransom money into their operations: better tools, better malware, and more resources to manage the operations. They even use some of the money to bribe insiders into leaking passwords or even unleashing the ransomware internally themselves. The relentlessness of ransomware keeps going on, fueled by advanced cyber weaponry, hard to trace cryptocurrencies, and the access to the Dark Web as global black marketplace.

DDoS attacks

Distributed denial of service, or DDoS, is a type of attack built to exploit the limited capacity of the systems and the networks. As we discussed, the capacity of a system will always be limited, and even though it may be sufficient to handle all regular requests, it will inevitably fail when the load exceeds that capacity.

A DDoS attack uses a distributed grouping of computers devices attached to the Internet as a singular force to bring down the target with an overwhelming number of requests. This grouping of computers, or computerized devices, is referred to as a botnet. A botnet is controlled from a centralized location but can consist of up to millions of devices working as one. The word botnet is a contraction of the words "robot", or "bot", and "network", or "net". Hackers identify vulnerable devices online, which can be security cameras, routers, refrigerators, or any device that has computational capabilities, and recruit them into a botnet. They hack the device by exploiting a vulnerability, or by simply using the default credentials that are often left unchanged and gain control of it. Building and enhancing a botnet is the work of a specific type of cybercriminal known as a botnet master. Botnets are typically used for large scale operations and are the weapon of choice today to conduct DDoS attacks.

DDoS attacks can be conducted for intimidation purposes, as a show of strength. Law enforcement and intelligence agencies may resort to them as a disruption tactic against adversaries that are planning an attack. Some cyber criminals use them for hacktivism because it creates visibility for the cause and gets them in the news. Other cyber criminals use them for extorsion, a bit in the same way that ransomware is used. They will DDoS a target repeatedly and bring it offline until the victim agrees to pay for the attack to stop.

Cyber vandalism

There has been an uptick in the deployment of a special type of malware recently known as a "wiper". As the name suggests, the malware is designed to "wipe out" systems and render them unusable. There are different ways for the malware to achieve that goal, and the consequences can be devastating. Unlike ransomware, the victim is not faced with a hard choice of how to recover the data, the data is most likely permanently lost. The goal of the attacker is destruction, not extorsion. It is meant to paralyze the victim and cause extensive damage to its operation. It is more commonly seen being used as a weapon of cyber warfare than cyber criminality.

The following article provide a great analysis, including a timeline, on the use of wiper malware:

What Is the Wiper Malware? Is It Worse Than a Ransom

Security controls for availability

Guaranteeing 100% availability is not possible. When discussing availability requirements and goals, it is best to keep in mind that events will occur and be out of our control in some cases.

Load balancing

The concept of load balancing is to have several devices that work similarly and to share the load between them. A load balancer will analyze the saturation of the devices and distribute the requests accordingly. If a device were to break down or be otherwise unavailable, the load is shared amongst the remaining devices and continuity is maintained.

Load balancing is an important mechanism used by service providers of all kinds to create resilience in the operations. Cloud service providers make great use of load balancing to efficiently distribute the workload in the pool of available resources for their clients.

Avoiding bottlenecks

Bottleneck is a term used to represent a point of congestion in a system. The term can be used in a business sense, where a chain of manipulations is slowed down because one of those manipulation is slowing down the entire process. We would then say that this operation is

“bottlenecking” the process.

The concept applies to the online world as well, where a process is broken down into several subprocesses, and some dependencies occur. If one of the subprocess tends to congest, then it becomes a bottleneck.

Organizations must identify bottlenecks in their process and limit the negative impacts that they can have. This can be done by increasing the capacities of the device used to handle that process (vertical scaling out), or by adding devices that can share the load (horizontal scaling out). The process can also be retooled that have an architecture less prone to bottlenecks. In cloud computing, the preference is to use asynchronous processes rather than synchronous ones. A synchronous process must wait for the previous task to complete before it can start, whereas an asynchronous task can get started right away.

For example, if a client does an online purchase, there are numerous activities that need to happen. The purchase must go through, the client must be billed, the inventory must be updated, with new units ordered as needed, and the shipping must take place. To perform this synchronously would take a huge amount of time and would be very subject to bottlenecks. Instead, the purchase will be seen as an event, and that event will trigger multiple asynchronous subprocesses that will complete all these tasks in parallel. This is known as “event-driven architecture” and is very popular with distributed cloud services.

Avoiding single-point-of-failure

A complementary notion to that of bottleneck is the notion of a single-point-of-failure (SPOF). Some parts of the process can be performing adequately and have sufficient resources to not become a bottleneck, but if they fail the whole process goes down. That is a situation known as a single-point-of-failure and can be very disrupting.

Organizations will try to identify SPOF in all aspects of their operations and, when possible, rework the architecture to avoid them. The approach will leverage some of the same tools and methods already discussed: event-driven architecture, load balancing, asynchronous transactions, and other similar tactics.

Redundancy

As you can see, most of the security controls that protect availability have a commonality: they use redundancy to avoid being in a precarious situation. This can be seen at multiple levels of a clouddeployed service: multiple CPUs, lots of available memory, lots of available storage space, multiple servers, and even multiple data centers. Even the Internet is built in that regard. Communications over the Internet do not follow a dedicated path, but rather whichever path is available that is the fastest. If a branch goes down, the network adjusts and reroutes itself and tries to keep up the delivery of packets. After all, the Internet will always be a requirement for online systems to operate and as such it makes sense to build the communication network with as much resilience as possible to sustain disruption and attacks.

Distributed infrastructure

Cloud service providers make great use of redundancy in their infrastructure and use this as the backbone of their availability capabilities. They use multiple data centres to share load, provide resilience, and failover capacities for their clients who wishes to benefit from enhanced reliability.

In the next section, we will analyze the basic approach that cloud service providers use to create a content delivery network that enhance speed and reliability and sustains their operations during adverse conditions.

Content delivery network (CDN)

What follows is the definition of a content delivery network according to Wikipedia. In it, you can recognize some of the terminology that was already defined in this module, including high availability and performance bottlenecks:

“A content delivery network, or content distribution network, is a geographically distributed network of proxy servers and their data centers. The goal is to provide high availability and performance by distributing the service spatially relative to end users. CDNs came into existence in the late 1990s as a means for alleviating the performance bottlenecks of the Internet as the Internet was starting to become a mission-critical medium for people and enterprises. Since then, CDNs have grown to serve a large portion of the Internet content today, including web objects, downloadable objects, applications, live streaming media, on-demand streaming media, and social media sites. CDNs are a layer in the internet ecosystem. Content owners such as media companies and e-commerce vendors pay CDN operators to deliver their content to their end users. In turn, a CDN pays Internet service providers, carriers, and network operators for hosting its servers in their data centers.”

In the rest of this section, we will more fully discuss the concept of a content distribution network.

Basic implementation of a CDN

To better understand how a CDN works, we are going to use the following example. Let’s assume an organization that provides online training to students across the world. Training is provided by streaming audio-video content from the server to the student.

In this case, the role of a CDN is manyfold. At the basis, there is a geographical dispersion of the servers that will hold the content for the service to provide. Since streaming is taxing on the network, there will be congestion and bottlenecking if only one central server is providing the streaming content. The use of a CDN will allow the content to be replicated on several servers across the world. When a student reaches out to stream content, the service will be provided by a server that is located closer to that student from a geographical perspective. The content has less far to travel, so it is faster, and the communication does not hinder the rest of the operations.

Another role of the CDN in this situation is to increase the resilience of the operations. If a server of the CDN is down because of a malfunction, for maintenance, or is approaching is critical capacity, the requests can be rerouted to the next available CDN by proximity. In many cases, this will be barely perceptible by the end users.

The use of geographically dispersed servers can also server to tailor the content. For example, the default language used, or specific items that are restricted to some geographical locations.

Notice that a CDN implementation gives much higher resilience to DDoS attacks, because the attacker would need to target multiple data centres to bring the service down.

Amazon implementation

Amazon offers a CDN service named CloudFront. The service delivers data via over 450 globally dispersed points of presence. It uses automated network mapping and intelligent routing to sustain a high degree of availability to services that use it.

Make sure to read the following resource that details the Amazon implementation of a CDN:

What is a CDN

Azure implementation

Microsoft offers the Azure Content Delivery Network. This CDN optimizes streaming media and is scalable to handle worldwide traffic spikes and instantaneous high loads.

The following resource defines the implementation of a CDN offered by Microsoft Azure:

Azure Content Delivery Network

Internet resiliency

There's no denying that the Internet has become more than a commodity in this day and age. Failures to Internet-delivered operations can have devastating consequences and our reliance upon this global communication platform is still increasing. The global pandemic precipitated the transition to online services and there is no going back. In this situation, having resilient capabilities for content distribution is becoming critically important, and CDNs are a much-needed tool for a reliable transmission architecture.

Module 6 | Repudiation and nonrepudiation

Repudiation is denying an action; nonrepudiation raises confidence that a particular party performed it. An online system needs trustworthy identity, records, and evidence of what happened.

Authentication, digital signatures, message authentication, logging, and monitoring can support nonrepudiation. They provide assurance rather than absolute proof: stolen identities, altered records, coercion, and other failures can undermine a conclusion.

Repudiation and nonrepudiation

In the previous modules, we covered the three big pillars of information security: confidentiality, integrity, and availability. Together, those three attributes form the basis of protecting and preserving data and infrastructure for information systems, including for cloud deployments.

Many experts wish to add attributes in the consideration of information security. One attribute that gets added to the list sometimes is the notion of assurance: a degree of certainty in regard to the implementation of security controls in the information system infrastructure.

Another attribute that gets a lot of consideration is the notion of repudiation. Quickly stated, repudiation is the act of denying a certain activity. In the legal world, repudiation is often about denying having engaged into an agreement. In the information technology world, repudiation can be about an interaction with the information system, such as reading or writing information, or modifying the system's configuration. On the other hand, nonrepudiation is seen as an attribute of a system that provides assurance towards the entities behind certain activities. In other words, a system provides nonrepudiation when activities are tracked, and the users cannot deny having committed them.

The notions of repudiation and nonrepudiation are unusual in information systems because depending on the system, the desired attribute can be one or the other. Let's explore the implications of each of these attributes.

Benefits of repudiation

Certain actions in information systems require anonymity. The users behind the actions need to be able to perform the activity without exposing themselves. For example, if you provide feedback on a teacher during a semester, would your feedback be the same if your name is attached to the feedback and the teacher would be able to identify the author of the rating? Your feedback would likely be influenced by such a situation. This is a system that requires repudiation.

Another system that benefits from repudiation, although this stance is much more controversial, is public discourse. In order for people to feel free to express ideas, opinions, and thoughts without the fear of repercussions, the public forums that allow for this must provide repudiation. This would include social media. If it were impossible to post anonymously on social media, this could have a deterrent effect on public discourse and free speech.

The following news report provides an insight into the concept of online anonymity:

Social Media: Should people be allowed to be anonymo

As you can see, the concept of repudiation is not a clear-cut concept. Certain cases will benefit from, or require, that users be able to interact with the system anonymously.

Benefits of nonrepudiation

For most applications, interactions between the users and the system will require nonrepudiation. Information systems need to record and track manipulations to the systems, legitimate or otherwise, for many reasons. Of course, nonrepudiation has a goal of protecting confidentiality, integrity, and availability. For example, to ensure that only authorized users are accessing confidential information, we need to monitor the use (and potential abuse or misuse) of the system and its data. Beyond security, nonrepudiation helps to monitor trends in the system, which functionalities are popular in the application, and potential bottlenecks that could emerge. This is because nonrepudiation is mostly about visibility into the system and the interactions.

How to define the need for nonrepudiation

As you may have gathered, even a system with a need for repudiation or anonymity will still need some monitoring and tracking of the activities that happen in the system. This means that even if an activity is meant to be anonymous, the system will still have to track that the action took place and the parameters associated to it. Hence, expect that the system will always have a need to provide some level of visibility into the interactions. Later in the module, we will study the various ways to achieve this, but first let's have a look at the ways that repudiation can be achieved.

Pseudonymity

The first and foremost way to achieve a form of repudiation is to allow the use of pseudonyms. A pseudonym is literally a nickname: it is used to represent us without requiring ties to our real selves.

For example, let's assume that you want to join an online community. To register, the community asks that you provide an email address that will also be used as username, and to select a password. The confirmation and activation link will be sent to your email address and your account will become usable as soon as you validate the request. You could claim that this provides you with pseudonymity, since the email can be created especially for your account and not be used for anything else. Your interactions are tied to your account by that email and is therefore your pseudonym.

However, if the provider requires identifiable information upon registration, such as a phone number, or a credit card number, it becomes much harder to maintain the pseudonymity. Other pieces of information would have to be pseudonyms as well. For example, you could use a prepaid credit card and a virtual phone number through providers that offer that service.

This article explains how certain applications and services can provide you with a virtual, throwaway phone number that is not tied to your identity.

The 12 Best Free Internet Phone Calls Apps of 2023

Anonymity

What about anonymity? Can anonymity even be achieved in today's world? Many experts would argue that it is not possible to interact anonymously with an online service today, or at least not without a considerable amount of work and expertise.

In technical terms, you achieve anonymity by using a pseudonym that cannot be linked back to you. Your actions will be tracked and attached to the pseudonym, but if there is no way to track it back to your identity, you remain anonymous and achieve complete repudiation.

An example is the use of Bitcoin. Transactions done using Bitcoin are said to be anonymous, but that is a misleading statement. Every transaction is infamously tracked and made available for everyone to see in a distributed ledger. The transactions are tied to a Bitcoin wallet, which acts as a pseudonym. As long as the wallet is not traced to an actual person, anonymity is achieved. However, multiple links can be established that threaten the anonymous properties of the system. When the user wishes to convert that cryptocurrency to a fiat currency, a link will be established. The transactions themselves are sometimes enough to identify the person. The IP addresses used can be enough to identify the individual.

To learn more about the anonymity that can be achieved with Bitcoin, read the following article:

How Anonymous Is Bitcoin?

Limitations of anonymity

As you can see, achieving real anonymity when it comes to online interactions is notoriously difficult. After all, any transaction will generate numerous traces of the interactivity: records of smartphone interactions with cell towers, records of online activity going through your Internet service provider, cookies stored in your device, etc. It is something to keep in mind when a service

provider guarantees “anonymity”.

Thankfully, it is unlikely that you will have to provide for such a level of anonymity in an online service. Chances are that if you allow the use of a pseudonym, that will be the furthest towards anonymity that you will go. And that is not very far indeed. Most systems are actually much more susceptible to want a high level of nonrepudiation. In the next section, we will analyze how this can be achieved.

Implementation of nonrepudiation

As mentioned before, nonrepudiation began as a legal concept. The goal was to ensure that parties entering into an agreement would be held to it later and could not claim that they did not enter the bond. In information technology, the notion is broader, and includes most forms of interaction with an online system.

In literature, nonrepudiation is more commonly associated with the delivery and receipt of messages. However, since any online interaction is based upon sending and receiving requests, we can extrapolate the notion to encompass most interactions with online systems.

Let’s first agree on a reality of online interactions, which is that we can never be absolutely certain about the integrity of an operation. Therefore, using the word “proof” can be misleading when discussing information systems and nonrepudiation. It should actually be defined as a level of assurance, or a degree of confidence, that a certain party accomplished a given action. Unfortunately, we can never really prove beyond any doubt that it is the case.

Let’s explore some of the basic tools that are used to implement nonrepudiation for online services.

Authentication

At the foundation of nonrepudiation is the concept of authentication. Authentication will be revisited later in this course, but we are all familiar with the concept because we use it everyday. Authentication provides a level of assurance to the identification of a user. For instance, when you log onto an application, you provide identification (your username) and some justification that you are indeed who you claim to be. This could be a password that only you should know, or by using a device that has been entrusted to you.

Not all authentication schemes are equal, and some provide a much higher level of confidence than others. To have nonrepudiation, you need authentication. Note that the authentication effort can be to the pseudonym of the user. This is a secondary consideration. We may not know who is behind the pseudonym, but we want to check that the pseudonym is being used by the person to whom it belongs.

Encryption and digital signatures

In the previous module, we explored the concept of integrity. Protecting integrity relies on cryptographic tools, namely the use of asymmetric encryption and the creation of digital signatures. These notions resurface here, since providing nonrepudiation requires the system to have a level of confidence in the integrity of the information being exchanged. After all, how can we provide nonrepudiation if the system cannot protect the data in transit from tampering?

Using digital signatures provides several benefits to the system when it comes to nonrepudiation. First of all, the use of a private key identifies the party because no one else has access to the private key, at least in principle. Secondly, a digital signature adds a layer of integrity and prevents the tampering of the information by interfering entities.

Biometric authentication

Another mechanism that can be helpful to protect the nonrepudiation aspect of transactions is to incorporate the use of biometric information into the chain of trust. Experts feel that if a system is compromised it could expose passwords, private keys, and all other sorts of virtual information to the point where an attacker could impersonate another user entirely. The use of a biometric measure to engage into the transaction can thwart this overtaking because it involves a non-virtual component: a fingerprint, facial scan, or another “measure of life”.

Message authentication code

An interesting way to provide authenticity, integrity, and nonrepudiation is to increase the level of confidence to the message being sent and received between the online system and the user. A common implementation to achieve this is to use a

mechanism known as a message authentication code, or MAC. A MAC, also referred to as a tag, is added to the message and allows the recipient to verify that the message was not altered. In this way, it acts as a digital signature but is more versatile since it does not rely on the use of a public key infrastructure.

The notion of message authentication codes can be complex. To get a better understanding, consult the following resource:

What Is A Message Authentication Code?

Logging

It is essential to create trustworthy transactions to achieve nonrepudiation, but it is equally important to track these transactions. Every auditable transaction should be logged, meaning that any transaction that you may wish to be able to trace back to an entity must be logged in the system.

Monitoring

From a security perspective, administrators must observe the transactions occurring to the system and ensure that everything that is going on is legitimate and controlled. This includes the nature of the transaction, their volume, and their provenance. Monitoring is commonly achieved by observing logs and looking for anomalies. However, modern cloud applications might be serving many requests that will quickly become overwhelming to monitor for a human being looking at raw data. For this reason, administrators typically resort to dashboards that provide an aggregation of data where anomalies will be quickly identified.

Limitations of nonrepudiation mechanisms

Even though the implementation of robust nonrepudiation mechanisms can provide a high level of confidence, there can never be certainty in the process. We are achieving higher and higher levels of certainty, but for now, not absolute certainty. Let’s have a look at the threats to nonrepudiation.

Data tampering

It is possible that data can be modified once it has been stored in databanks on the server-side. This could be the work of rogue insider, or even of system errors and data corruption. Such an event would result in data being in the system that the user would deny having generated.

Identity theft

As we mentioned, the notion of nonrepudiation is very dependent on the concept of authentication. If one’s identity is stolen to the point where the threat actor can authenticate and be recognized by the information system as the legitimate user, then nonrepudiation can no longer be achieved. The countermeasure to this threat is to increase the robustness of the authentication measure, but this comes with a heavier system, less intuitive and easy to use, and costlier to implement and manage.

Coercion

If a user is coerced into performing certain transactions into an information system, is there really anything that an information system can do? Actually, they might be able to limit the damage. For example, a banking system might have a cap on the amount of money that can be withdrawn in a 24-hour period. This mechanism is to limit the damage from an attacker that would coerce a user to withdraw funds. Other types of information systems can implement similar mechanisms to restrict, confirm, and verify sensitive interactions to limit the damage from coerced activities.